מחלקת תקשוב · רשתות · דף הנחיה למדריך

הצפנה וזהות

מאתב"ש ועד TLS 1.3 וכרטיס חכם: מה כל כלי מבטיח, איך הוא נראה בשטח,
ואיך הוא עובד מבפנים - עם הדגמה חיה לכל אלגוריתם.

שטח + רקע	30	95 דקות
רמת המיקוד	שקופיות	משך מומלץ

מותאם לטכנאי שטח · סביבת Windows מנוהלת · ניתן לפיצול לשני מפגשים

לפני שמתחילים

שטח + רקע	30	95 דקות
רמת המיקוד	שקופיות כולל שער ומעבר	משך מומלץ

מטרת השיעור

לתת לטכנאי תשובה אחת לכל כלי הצפנה שהוא פוגש: **מה בדיוק הכלי הזה מוכיח?** רוב הטעויות בשטח הן לייחס לכלי הבטחה שהוא לא נותן.

מה החניך צריך לדעת

בסיום החניך יבדיל בין קידוד, הצפנה והסתרה; יסביר מה Hash, סימטרית, אסימטרית וחתימה נותנים ומה לא; יקרא שגיאת תעודה ויצביע על החוליה שנכשלה; ויסביר למה PIN קצר מספיק לכרטיס חכם.

הכנה מראש

- לפתוח את המצגת ב-Chrome או ב-Edge במחשב של המקרן ולעבור על כל השקופיות. אין צורך ברשת: כל ההדגמות מחושבות מקומית, גם כשהקובץ מוגש מ-IIS ב-HTTP.
- **שדות קלט לוכדים את המקלדת:** כשהסמן בתוך תיבה, החצים לא מעבירים שקופית. Esc או לחיצה מחוץ לשדה מחזירים את הניווט.

היקף השיעור

לא מלמדים מימוש, לא הגדרת PKI ולא נוהל שחרור כרטיס. מספר ניסיונות ה-PIN ותהליך השחרור נקבעים במדיניות היחידה, וההדגמה משתמשת ב-3 להמחשה בלבד.

חלוקת זמן מוצעת

חלק	מה מעבירים	דקות
פתיחה	שלוש מטרות, Base64, סטגנוגרפיה וצופן החלפה (שקופיות 1-5)	15
ארבעה כלים	Hash, סימטרית, אסימטרית, היברידית (6-10)	15
תעודות	TLS בעין הטכנאי, חתימה, שרשרת ותקלות (11-14)	14
כרטיס חכם	אתגר ותגובה, PIN, איתור תקלות, סיכום חלק א׳ (15-18)	11
חלק ב׳	פיצוח תדירויות, SHA-256, XOR (19-22)	10
אלגוריתמים	AES, RSA, דיפי-הלמן, חתימה במספרים (23-26)	14
סגירה	לחיצת יד TLS 1.2, 1.3 מול 1.3, גבולות, סיכום (27-30)	16

פיצול לשני מפגשים

עוצרים בשקופית 18; המפגש השני נפתח ב-19. בזמן קצר מדלגים על 22 ו-26, לא על 27 ו-29.

אין מפתח, אין הצפנה

הצפנה נותנת שלושה דברים שונים: **סודיות** (מי שאין לו מפתח רואה רעש), **שלמות** (שינוי מתגלה) ו**אימות** (מוכח מי שלח). כמעט אף כלי לא נותן את שלושתם לבד.

Base64 נראה מוצפן, אבל כל אחד הופך אותו בחזרה - בלי מפתח

שקופית 3 · Base64 חי

הקלידו סיסמה ושאלו "זה מוצפן?". רוב הקבוצה תגיד כן. אז הצביעו על השורה התחתונה: פוענח מיד. בשטח פוגשים את זה בקובצי הגדרות ובסקריפטים עם "סיסמה מוסתרת".

שקופית 4 · סטגנוגרפיה

שתי התמונות נראות זהות. "הגבר ביט אחרון" מציג רק את הביט הנמוך: בתמונה עם המסר (השמאלית) מופיע פס רעש בראש התמונה. הצפנה לא מסתירה שיש תקשורת; סטגנוגרפיה לא מגינה על התוכן.

שקופית 5 · צופן החלפה

אתב"ש: "בבל" הופך ל"ששך" (ירמיהו כה, כו). בקיסר מזיזים את הטבעת הפנימית - וזה כל המפתח. החולשה שחוזרים אליה בחלק ב': אות נפוצה נשארת נפוצה גם אחרי ההחלפה.

איך להעביר

לפני כל הדגמה - שאלה. "מה יקרה אם...?" ורק אז לוחצים. ההדגמות בנויות כדי שהקבוצה תנחש לפני שהיא רואה.

עקרון קרקהוף

מניחים שהאויב יודע את השיטה, ורק המפתח סודי. "אלגוריתם סודי" אינו אבטחה. זה גם מה שמאפשר להחליף אלגוריתם כשהוא נשבר.

לכל כלי תפקיד, ולכל כלי גבול

כלי	נותן	לא נותן	בשטח
Hash	מגלה כל שינוי	לא מסתיר, לא מוכיח מי	בדיקת קובץ שהורד, שמירת סיסמאות
סימטרית	סודיות לכמויות גדולות, מהר	פתרון להעברת המפתח	BitLocker, ארכיון מוצפן, Wi-Fi עם סיסמה
אסימטרית	הסכמה על מפתח בלי סוד משותף	מהירות	החלפת מפתחות ב-TLS ו-VPN
חתימה	שלמות וזהות החותם	הסתרת התוכן	עדכוני תוכנה, מנהלי התקן

שקופית 7 · Hash

שני משפטים שנבדלים בספרה אחת, וכמחצית מ-256 הביטים שונים. בשטח: Get-FileHash ו-certutil -hashfile מובנים ב-Windows. MD5 ו-SHA-1 - לבדיקת תקלות בלבד.

שקופית 8 · סימטרית

הזיזו את הסליידר מ-2 ל-40: 15 מפתחות ב-6 משתתפים, 780 ב-40. כל מפתח צריך להגיע לשני הצדדים בדרך בטוחה. זו הבעיה שהאסימטרית פותרת.

שקופית 9 · אסימטרית

מנעול פתוח עובר מדנה ליוסי, נסגר על הקופסה, ורק המפתח הפרטי של דנה פותח. מי שמעתיק את המנעול לא מרוויח כלום: עם מנעול אפשר רק לסגור.

שקופית 10 · היברידית

פעם אחת מסכמים מפתח באסימטרית, ומשם הכול זורם בסימטרית. כך עובדים TLS, VPN ודוא"ל מוצפן.

טעות נפוצה

לא לתת יחס מהירויות מדויק בין סימטרית לאסימטרית. הוא תלוי באלגוריתם ובחומרה. אומרים "סדרי גודל".

המנעול מבטיח ערוץ וזהות שרת - ולא יותר

מנעול בדפדפן מוכיח שני דברים: אף אחד בדרך לא קורא ולא משנה, והשרת מחזיק מפתח פרטי של תעודה תקפה **לשם שבשורת הכתובת**. הוא לא מוכיח שהאתר הגון, ולא שזה האתר שהתכוונו אליו.

שקופית 12 · חתימה חיה

חתמו. שנו 7 ל-8 ובדקו: אדום. החזירו 7: ירוק. הוסיפו רווח בסוף: אדום. חתימה לא מסתירה את המסמך - היא מוכיחה מקור ושלמות.

שקופית 13 · שרשרת תעודות

הריצו "תקין" כדי לראות את סדר הבדיקות, ובכל תרחיש אחר שאלו לפני ההרצה איזו חוליה תיכשל. הבדיקה נעצרת בחוליה הראשונה שנכשלת.

שקופית 14 · ארבע תקלות תעודה

מה רואים	סיבה אופיינית	איפה בודקים
ERR_CERT_DATE_INVALID	התעודה פגה - או ששעון התחנה שגוי	Certificate Viewer · w32tm /query /status
ERR_CERT_COMMON_NAME_INVALID	נכנסו ב-IP או בשם קצר	Subject Alternative Name
ERR_CERT_AUTHORITY_INVALID	שורש לא מותקן, או שהשרת לא שולח תעודת ביניים	certlm.msc · Certification Path
"לא ניתן לבדוק ביטול"	אין גישה ל-CRL או ל-OCSP	certutil -verify -urlfetch

שני תרחישים מפתיעים

"שעון שגוי בתחנה" נראה בדיוק כמו "פג תוקף", והתיקון בתחנה ולא בשרת. "חסרה תעודת ביניים" עובד בחלק מהלקוחות (שמורידים אותה בעצמם) ונכשל באחרים - תקלה של "אצלי זה עובד".

"המשך בכל זאת" אינו נוהל

זה בדיוק התרחיש שהתעודה נועדה לחסום. מתעדים את השגיאה ומתקנים את החוליה. ובארגון: בדיקת תעבורה מוצפנת עם שורש פנימי היא סיבה לגיטימית לכך שהמנעול לא מוכיח שאין אף אחד באמצע.

המפתח הפרטי לא זז, וה-PIN נבדק בכרטיס

הכרטיס מחזיק מפתח פרטי שנוצר בשבב ולא ניתן לייצוא, ותעודה שקושרת אותו לשם המשתמש. בכניסה לדומיין השרת שולח אתגר אקראי, והכרטיס חותם עליו מבפנים. ב-Windows זה Kerberos מבוסס תעודות (PKINIT), ולכן גם כאן שעון מסונכרן ושרשרת תקינה הם תנאי.

שקופית 15 · אתגר ותגובה

עקבו אחרי הלולאה: אתגר, חתימה בשבב, חתימה חוזרת ונבדקת. מה לא זז אף פעם: המפתח הפרטי וה-PIN. הקלטה לא עוזרת לתוקף כי האתגר שונה בכל פעם.

שקופית 16 · PIN חי

תנו למישהו לנחש שלוש פעמים. אחרי השלישית גם ה-PIN הנכון (2580) לא פותח. PIN קצר בטוח יותר מסיסמה ארוכה במצב אחד: כשהבדיקה בחומרה שסופרת ניסיונות.

שקופית 17 · כשכרטיס לא עובד: מלמטה למעלה

שלב	בודקים	איך
1	**קורא מזוהה**	מנהל ההתקנים, נורית, כבל וחיבור
2	**השירות פועל**	services.msc-ב (SCardSvr) Smart Card
3	**הכרטיס נקרא**	certutil -scinfo
4	**תעודה תקינה**	תוקף, שרשרת מלאה, לא בוטלה
5	**PIN וזמן**	PIN לא חסום, שעון מסונכרן לדומיין

ההיקף מצביע על החשוד

כל התחנות - קורא או מנהל התקן. תחנה אחת - שירות או התקנה מקומית. משתמש אחד - הכרטיס או התעודה שלו. זה תהליך שיעור 5 מיושם על כרטיס חכם.

מה לא להגיד

לא מציגים מספר ניסיונות אחר כעובדה, ולא מלמדים "איפוס" כרטיס. כרטיס חסום הוא אירוע מנהלתי לפי נוהל היחידה. מה שמעבירים הלאה: תסמין, היקף, ופלט certutil -scinfo.

מכאן ההדגמות מחשבות את האלגוריתמים האמיתיים

שקופית 19 היא נקודת הפיצול. SHA-256 ו-AES בהדגמות תואמים את התקנים (נבדקו מול ספריות סטנדרטיות); המספרים ב-RSA ובדיפי-הלמן קטנים בכוונה כדי שאפשר יהיה לבדוק אותם בראש.

שקופית 20 · ניתוח תדירויות

גררו את הסליידר לאט: העמודות זזות כמקשה אחת, וכשהן נוחתות על הקווים המקווקווים הטקסט נקרא. ״פצח אוטומטית״ נוחת על הזזה 7. אחר כך ״טקסט קצר״ - והניחוש שגוי (16). זה בכוונה: עם מעט טקסט אין סטטיסטיקה.

שקופית 21 · SHA-256 מבפנים

הקלידו אות אחר אות: בכל הקשה כחצי מהריבועים מתהפכים. אות עברית היא שני בתים ב-UTF-8, ומ-56 בתים הקלט כבר דורש שני בלוקים.

שקופית 22 · XOR

״הרץ״ ממלא את השורות עמודה אחרי עמודה, ובשורה האחרונה הטקסט חוזר: $(P \oplus K) \oplus K = P$. זה הבסיס של צפני זרם ושל AES במצב GCM.

הנקודה המעשית

שימוש חוזר במפתח זרם חושף את ההודעות: $C_1 \oplus C_2 = P_1 \oplus P_2$. מכאן הדרישה למספר חד-פעמי חדש בכל הודעה ב-TLS.

אם נשאלים ״אפשר לפצח AES כמו את קיסר?״

לא. אפקט המפולת (שקופית 21) מוחק את צורת השפה, ולכן לניתוח תדירויות אין על מה להיתפס.

אלגוריתם אחד מכל סוג, במספרים שאפשר לבדוק

שקופית 23 · AES

נגנו את עשרת הסבבים, ואז צעדו ידנית בסבב הראשון: SubBytes משנה את כל 16 התאים, ShiftRows רק מזיז שורות, MixColumns מערבב עמודה, AddRoundKey מוסיף מפתח סבב. "הפוך ביט אחד במפתח" משנה כמחצית מ-128 ביטי הפלט.

שקופית 24 · RSA

ברירת המחדל הקלאסית: p=61, q=53, e=17. "פרק את n כמו תוקף" מוצא את p ו-q מיד ומשם את d. נסו גם e=3 עם q=31: אין d, וזה חלק מהחשבון.

שקופית 25 · דיפי-הלמן

סיפור הצבעים: קל לערבב, כמעט בלתי אפשרי להפריד. הזיזו את a ו-b: הסוד תמיד זהה בשני הצדדים. דיפי-הלמן לבדו לא יודע מי בצד השני, ולכן ב-TLS השרת חותם על ההחלפה.

שקופית 26 · חתימה במספרים

h הוא ה-Hash של המסמך מצומצם ל-3233, s = h^d mod n, והבדיקה משווה את s^e mod n ל-h. בגלל הצמצום יש סיכוי של כ-1 ל-3233 ששינוי "יעבור" במקרה.

ערכי בדיקה

הדגמה	קלט	תוצאה צפויה
אתב"ש / קיסר 3	בבל	ששך / ההס
SHA-256	שלום	b7ac0398ef74193ab738b21df0912329…
AES-128	B נספח FIPS-197	3925841d02dc09fbdc118597196a0b32
RSA	p=61, q=53, e=17, m=65	n=3233, d=2753, c=2790
דיפי-הלמן	p=23, g=5, a=6, b=15	A=8, B=19, s=2

סבב הודעות אחד, ומשם הכול מוצפן

שקופית 27 היא המרכזית של חלק ב׳ - קחו בה זמן. צעדו ידנית, עשרה צעדים. כל הודעה צבועה לפי מה שמגן עליה: גלוי, מפתחות לחיצת יד, או מפתחות יישום.

צעד	הודעה	מה חשוב להגיד
1-2	**ClientHello / ServerHello**	שניהם כוללים key_share - החצי של דיפי-הלמן. גלוי, וזה בסדר.
3	**חישוב מקומי**	שני הצדדים מגיעים לאותו סוד. שום מפתח לא נשלח.
4-5	**EncryptedExtensions, Certificate**	מכאן מוצפן - כולל התעודה, שב-TLS 1.2 עברה גלויה.
6	**CertificateVerify**	השרת חותם על כל ההודעות, כולל ה-key_share. זה מה שמונע מתוקף באמצע להחליף אותו.
7-8	**Finished בשני הכיוונים**	HMAC על כל לחיצת היד. הלקוח בודק את השרשרת לפני שהוא שולח.
9-10	**Application Data**	מפתחות יישום מאותו סוד. מידע ראשון אחרי סבב אחד (1-RTT).

שקופית 28 · 1.2 מול 1.3

החליפו בין הגרסאות ותנו לקבוצה לזהות מה השתנה: התעודה מוצפנת, החלפת המפתחות תמיד עם דיפי-הלמן זמני (סודיות קדימה), וסבב אחד פחות.

מה לא השתנה

כתובות IP, פורטים, שם האתר (SNI) וגודל ותזמון התעבורה. ECH מצפינה גם את SNI, אבל עוד לא בכל מקום. זו גם הסיבה שלוכד תעבורה מראה ב-1.3 פחות מבעבר.

חיבור לשיעור 3

בשיעור 3 ברשתות לחיצת היד הוצגה כ״Hello, תעודה, גזירת מפתחות ו-Finished״. כאן רואים כל חלק, ולמה כל אחד נחוץ.

מה ההדגמות לא אומרות

אל תדלגו על שקופית 29. הטעות הנפוצה אחרי שיעור כזה היא לחשוב ש"RSA זה החשבון הזה". החשבון נכון, אבל בלי ריפוד, בלי גדלים אמיתיים ובלי מצבי הפעלה הוא לא בטוח.

מה הופשט

RSA במספרים זעירים ובלי ריפוד (בפועל: 2048 ביט ומעלה, OAEP ו-PSS). AES בבלוק בודד (בפועל: GCM עם מספר חד-פעמי). התרשימים של PKINIT ו-TLS מראים את העיקרון בלבד.

מה כן אמין

SHA-256 ו-AES תואמים את התקנים: נבדקו מול hashlib ו-OpenSSL. מפולת, פירוק לגורמים, לוגריתם בדיד ושרשרת חתימות הם בדיוק העקרונות שבמערכות אמיתיות.

שאלות צפויות

שאלה	תשובה קצרה
אם יש HTTPS, למה עדיין יש פישינג?	תעודה מוכיחה רק שלשרת יש מפתח לשם שבשורת הכתובת. גם לאתר מתחזה יכולה להיות תעודה תקפה לשם שלו.
למה לא משתמשים רק ב-RSA?	איטית ומוגבלת בגודל. משתמשים בה (או ב-ECDHE) רק להסכמה על מפתח ולחתימה.
למה השגיאה רק בתחנה אחת?	שעון, שורש חסר במאגר האמון, או מטמון. בודקים w32tm ו-certlm.msc.
מה קורה אם רשות התעודות נפרצת?	אפשר להנפיק תעודה "תקינה" לכל שם. לכן יש ביטול תעודות ומאגר אמון מנוהל.
מנהל הרשת רואה את הסיסמה שלי?	שרת תקין שומר Hash עם מלח. בכרטיס חכם אין סיסמה שעוברת בכלל.
מחשב קוונטי ישבור הכול?	מחשב גדול מספיק ישבור RSA ו-ECC. AES ו-SHA-256 נפגעים פחות. המעבר לאלגוריתמים עמידים כבר מתחיל.

לא כותבים קריפטוגרפיה לבד

הקוד במצגת הוא כלי הוראה. במערכת אמיתית משתמשים בספריות מוכרות ובהגדרות מומלצות.

מהלך המצגת ודגשים למדריך

מס׳	שלב	תוכן
1-2	**שער ומפה**	גלוי מול מוצפן; שני חצאים; ״מה הכלי מוכיח?״
3-5	**מה זה בכלל**	Base64 חי, מסר בביט האחרון, גלגל אתב״ש וקיסר.
6	**ארבעה כלים**	✓ ו-✗ לכל כלי.
7-10	**Hash עד היברידית**	מפולת, רשת מפתחות, מנעול פתוח, זרם מידע.
11	**TLS לטכנאי**	מה המנעול מבטיח ומה המאזין רואה.
12-14	**חתימה ותעודות**	חתימה חיה, בודק שרשרת, ארבע שגיאות.
15-17	**כרטיס חכם**	אתגר ותגובה, מקלדת PIN, בדיקה מלמטה למעלה.
18	**סיכום חלק א׳**	שבעה כללים לשטח.
19	**מעבר**	חלק ב׳ · רקע תיאורטי.
20-22	**קלאסי, Hash, XOR**	פיצוח תדירויות, רשת ביטים, XOR הפיך.
23-26	**אלגוריתמים**	AES בצעדים, RSA, דיפי-הלמן, חתימה במספרים.
27-28	**TLS 1.3**	לחיצת יד בעשרה צעדים; 1.2 מול 1.3.
29-30	**גבולות וסיכום**	מה הופשט; השרשרת שמחברת את הכול.

מילון קצר למדריך

מונח	הגדרה	מונח	הגדרה
Hash	טביעת אצבע באורך קבוע, חד-כיוונית.	**HMAC**	Hash עם מפתח סודי.
תעודה	מסמך חתום שקושר מפתח ציבורי לשם.	**SAN**	רשימת השמות שהתעודה תקפה להם.
CRL / OCSP	בדיקה אם תעודה בוטלה.	**ECDHE**	דיפי-הלמן זמני על עקומים.
סודיות קדימה	דליפת מפתח לא חושפת הקלטות ישנות.	**SNI**	שם האתר בתחילת TLS, גלוי לרוב.
PKINIT	כניסה ל-Kerberos בתעודה.	**RTT**	זמן הלוך-חזור ברשת.

שאלת סיום

בקשו ממישהו לתאר במשפט אחד מה קורה כשנכנסים לאתר. אם יש בתשובה הסכמה על מפתח, תעודה, חתימה והצפנה סימטרית - השיעור עבר.